

Matriz de seguridad — contenido HTML/JS en LMS/CMS educativos

Ernesto Serrano Collado · info@ernesto.es

2026-06-14

Índice

1. Tabla resumida (para el cuerpo del artículo)	1
2. Matriz técnica completa (anexo)	2
3. Mitigaciones emparejadas (riesgo → mitigación → limitación)	5
4. Tabla de concienciación (perfil no técnico)	5

Evidencia verificada contra el HEAD de cada repositorio (junio 2026). Cada celda “Cita” remite a `archivo:línea`. Las afirmaciones de comportamiento del navegador están marcadas [hecho] (verificado en código o prueba) o [inferencia].

SHAs de referencia: `mod_exelearning 2c5473d` · `mod_exeweb 60d24fb` · `mod_exescorm e985f4d` · `moodle 2104c372962` (5.x, code en public/) · `exelearning 8101f54e` · `wp-exelearning 9eb07ff` · `omeka-s-exelearning 33faf89` · `wp-franer 7fbf694`.

1. Tabla resumida (para el cuerpo del artículo)

Plataforma / recurso	¿Ejecuta JS del autor?	¿Mismo origen que el LMS?	sandbox del iframe	Aislamiento real
mod_page (Página)	Sí (verificado en vivo: ejecuta <code><script></code>)	Sí	— (no es iframe)	Ninguno server-side (<code>noclean</code>); gated por capacidad (<code>RISK_XSS</code>)
mod_scorm (core)	Sí	Sí	ninguno	Ninguno (confía en el SCO)
mod_h5pactivity / core_h5p	Parámetros No / librerías Sí (<code>preloadedJs</code>)	Sí (<code>about:blank</code> hereda origen)	— (<code>contentDocument.write</code> , sin sandbox)	Parámetros filtrados por semántica; el JS de librería corre <i>same-origin</i> , gate <code>h5p:updatelibraries</code>
mod_exelearning	Sí	Sí	<code>allow-scripts</code> <code>allow-same-origin</code> <code>allow-popups allow-forms</code> <code>allow-popups-to-escape-sandbox</code>	Parcial (bloquea top-nav y modals)
mod_exeweb	Sí	Sí	ninguno	Ninguno
mod_exescorm	Sí	Sí	ninguno	Ninguno
wp-exelearning	Sí	Configurable: secure opaco (def.) / legacy same-origin	<code>secure: allow-scripts</code> <code>allow-popups · legacy: +</code> <code>allow-same-origin</code>	Fuerte en <code>secure</code> (origen opaco); parcial en <code>legacy</code>
omeka-s-exelearning	Sí	Configurable: secure opaco (def.) / legacy same-origin	<code>secure: allow-scripts</code> <code>allow-popups</code> <code>allow-popups-to-escape-sandbox</code> <code>· legacy: +</code> <code>allow-same-origin</code>	Fuerte en <code>secure</code> (origen opaco); ahora también <code>allow-popups</code> vistas públicas
wp-franer (referencia)	Sí, aislado	No (srcdoc opaco)	<code>allow-scripts</code> <code>allow-forms + CSP</code> inyectada	El más fuerte

Lectura rápida: *ejecutar JavaScript del autor no es el problema; el problema es ejecutarlo **con el mismo origen** que el LMS y **sin** una frontera explícita*. Las dos columnas que de verdad importan son “mismo origen” y “aislamiento real”.

1.1 Matriz de riesgo formal

Criterio de clasificación explícito (referenciado desde la sección 3.4 del artículo): siete dimensiones observables más la separación entre **impacto máximo demostrado** (verificado en laboratorio) e **impacto inferido** (deducido del modelo del navegador). “SS” = *server-side*.

Mecanismo	JS autor	Mismo origen	Rol p/ publicar	Rol visitante	Token en DOM	CSP restr.	Cap. mutadora SS	Impacto máx. demostrado	Impacto inferido
mod_page	Sí	Sí (top)	profesor/gestor (addinstance)	cualquiera	Sí (sesskey)	No	Sí (servicios AJAX)	autoedición del propio perfil (vivo)	acciones acotadas por el rol del visitante
mod_scorm	Sí	Sí	profesor	cualquiera	Sí	No	Sí (gated savetrack)	lectura de DOM/sesskey (vivo)	forja acotada por validación SS
H5P · parámetros	No (filtrado)	Sí	—	cualquiera	n/a	No	n/a	control negativo (vivo)	—
H5P · librería	Sí (preloadedJs)	Sí	manager (updatelibraries)	cualquiera	Sí	No	Sí	ruta en código + PoC validada (manual) lee sesskey y forja (vivo)	JS arbitrario same-origin
mod_exelearning (legacy)	Sí	Sí	profesor	cualquiera	Sí	No	Sí	SecurityError (vivo Chromium+FF146)	escalado por rol
mod_exelearning (secure)	Sí	No (opaco)	profesor	cualquiera	No (token solo-lectura)	Sí	solo vía puente validado	— (solo código)	aislado
mod_exeweb / mod_exescorm	Sí	Sí	profesor	cualquiera	Sí	No	Sí	— (solo código)	acceso total same-origin
wp-exelearning / omeka-s-exelearning (secure)	Sí	No (opaco)	autor/editor	cualquiera	No	Sí	—	opaco (vivo, Chromium+FF146)	aislado
wp-franer (referencia)	Sí, aislado	No (srcdoc opaco)	autor	cualquiera	No	Sí	—	— (solo código)	padre protegido por SOP

2. Matriz técnica completa (anexo)

2.1 mod_exelearning (2c5473d)

Atributo	Valor	Cita
Cómo se publica	El profesor sube un .elpx; se extrae y se sirve por pluginfile.php	lib.php:513-568
HTML/JS arbitrario	Sí (HTML/JS del autor del paquete)	view.php:446-447
JS se ejecuta	Sí	iframe allow-scripts
Mismo origen	Sí (\$CFG->wwwroot único)	view.php:446-447
Usa iframe	Sí, #exelearningobject	view.php:446-447
sandbox	allow-scripts allow-same-origin allow-popups allow-forms allow-popups-to-escape-sandbox	view.php:446-447
allow-top-navigation	No (omitido a propósito)	view.php:446-447
allow-popups-to-escape-sandbox	Sí (residuo a quitar)	view.php:446-447
CSP	No emitida	lib.php:513-568
Permissions-Policy	No emitida (pendiente)	lib.php:513-568
X-Frame-Options	No (en pluginfile); core pone sameorigin en páginas	weblib.php:1604-1605
postMessage	Sí, solo en el editor (no en el visor)	amd/src/editor_modal.js:441-449
Valida event.origin	Sí (editor)	editor_modal.js:441-449
Valida event.source	Sí (=== iframe.contentWindow)	editor_modal.js:441-449
Token/contexto	sesskey validado server-side en track.php	track.php:40, view.php:387-390
Acceso a parent	Sí (mismo origen)	bridge SCORM
Acceso a cookies no-HttpOnly	Sí (mismo origen)	mismo origen
Acceso al sesskey	Sí (va en la URL de track.php, legible desde el DOM/JS)	view.php:387-390
Localiza formularios edición	Sí, si el DOM padre los tiene	mismo origen

Atributo	Valor	Cita
Cambios reales	No demostrado (server valida <code>sesskey</code> + <code>capability</code>)	<code>track.php:40</code>
Mitigaciones	Sandbox parcial; <code>require_capability</code> en <code>pluginfile</code> ; <code>require_sesskey</code> server-side	<code>lib.php:513-568</code> , <code>track.php:40</code>
Riesgos que quedan	XSS cross-component same-origin (riesgo residual)	—
Impacto de IA sin revisar	Alto: JS generado se ejecuta con el origen de Moodle	—

Dependencias **duras** de same-origin (impiden quitar `allow-same-origin` sin reescribir el bridge): 1. El padre lee `iframe.contentDocument` para mapear `objectid` → `js/scorm_tracker.js:75-86` y `:151-154`. 2. El hijo (pipwerks) recorre `window.parent` buscando `window.API` → `assets/scorm/SCORM_API_wrapper.js:62-118`. 3. El *teacher-mode hider* inyecta CSS en `contentDocument` → `classes/local/ui/teacher_mode_hider.php:44-61`.

2.2 mod_exeweb (60d24fb) y mod_exescorm (e985f4d)

Atributo	mod_exeweb	mod_exescorm
iframe	<code>embed_general.mustache:32-34</code>	<code>player.php:283-285</code> (noscript)
sandbox	ninguno	ninguno
HTML/JS arbitrario	Sí	Sí
Mismo origen	Sí	Sí
SCORM API walk	No (sin tracking)	Sí (<code>SCORM_API_wrapper.js:71-78,140-142</code>)
sesskey	—	URL param (<code>datamodels/scorm_12.js:19-24</code>)
CSP en pluginfile	No (<code>lib.php:448-512</code>)	No (<code>lib.php:1064-1142</code>)
teacher-mode hider	Sí (<code>locallib.php:90-107</code>)	—

2.3 Moodle core: mod_scorm (2104c372962)

Atributo	Valor	Cita
iframe del SCO	sin sandbox	<code>public/mod/scorm/player.php:279-285</code>
API discovery	<code>myFindAPI</code> recorre <code>win.parent</code> y <code>window.opener</code>	<code>loadSCO.php:113-122</code> , <code>:128-129</code>
sesskey	<code>confirm_sesskey()</code> antes de guardar	<code>datamodel.php:53</code>
Capability	<code>mod/scorm:savetrack</code>	<code>datamodel.php:56</code>
Mismo origen	Sí (<code>wwwroot/pluginfile.php</code>)	<code>locallib.php:2323,2327</code>

Veredicto: `mod_scorm` corre HTML/JS no confiable **sin sandbox** — más débil que `mod_exelearning`. Su defensa es server-side (`sesskey` + `capability`), no aislamiento del cliente.

2.4 Moodle core: core_h5p / mod_h5pactivity (2104c372962)

Atributo	Valor	Cita
iframe	<code>src="about:blank"</code>	<code>h5piframe.mustache:33</code>
Construcción	<code>contentDocument.write(...)</code>	<code>h5p.js:390-394</code>
Origen del contenido	hereda el del padre (same-origin) [hecho]	<code>h5p.js:391-394</code> (nota verificada)
HTML/JS arbitrario (parámetros)	No: <code>content.json</code> validado contra la semántica; <code>filter_xss</code> sin <code><script></code> ni <code>on*</code>	<code>h5p.classes.php:2260-2282</code> (<code>filterParameters</code>), <code>:4303-4384</code> , <code>:5033-5054</code>
HTML/JS de librería (preloadedJs)	Sí: código de confianza, <code><script src=pluginfile.php/.../core_h5p> same-origin</code> y sin sandbox	<code>player.php:484-500</code> , <code>h5p.js:391-437</code>
Gate de instalación de librería	<code>moodle/h5p:updatelibraries</code> (arquetipo manager , RISK_XSS), evaluada contra quien sube; profesorado solo <code>h5p:deploy</code>	<code>lib/db/access.php</code> , <code>helper.php:210-224</code> , <code>api.php:403-405</code> , <code>h5p.classes.php:1577-1579</code>
Whitelist	Extensiones curadas (content + librería)	<code>framework.php:698-700</code>
postMessage handler	Valida <code>event.source===window.parent</code> y <code>event.data.context==='h5p'</code> ; no valida <code>event.origin</code>	<code>embed.js:38-46</code> , <code>h5p.js:457-465</code>
postMessage envío	<code>targetOrigin = '*'</code> (origen-agnóstico)	<code>embed.js:64-73</code> , <code>h5p.js:484-493</code>
<code>\$CFG->h5pcrossorigin</code>	CORS para media (img/audio/video), no para el iframe	<code>helper.php:383</code> , <code>config-dist.php:778-786</code>

Veredicto (matizado): hay que distinguir dos planos. En los **parámetros** de contenido, H5P **no ejecuta HTML/JS de autor**: filtra el texto con `filter_xss` contra una lista cerrada de etiquetas sin `<script>`

y descarta `on*` (`h5p.classes.php:4303-4384, :5033-5054`) — control negativo, más controlado por diseño que un `.elpx`. En el plano de las **librerías**, en cambio, **sí**: el `preloadedJs` de una librería es **código de confianza** que corre *same-origin* y sin sandbox (`player.php:484-500`, `h5p.js:391-437`); la barrera para que el autor introduzca su propia librería es la **capacidad** `moodle/h5p:updatelibraries` (gestión/administración, `RISK_XSS`), no el saneamiento — **mismo patrón que `mod_page`**. PoC: `poc/evil-h5p-library.h5p`; evidencia: `evidencias/resultados-h5p-library.json`. Además **no es inmune** por contenido: XSS documentados (MDL-67110, CVE-2024-43439 —XSS reflejado vía mensaje de error—, CVE-2024-3111 —stored XSS vía SVG—) y precedente de RCE por import de `.h5p` (CVE-2026-30875, Chamilo). Su `postMessage` no valida `event.origin` (mitiga con `event.source + context`), patrón a no copiar a ciegas.

Acción privilegiada (Moodle, verificado en código): el contenido *same-origin* (Página, `.elpx`, SCO) lee `window.M.cfg.sesskey` y puede invocar servicios web **AJAX** como `core_user_update_users ('ajax' => true, cap moodle/user:update, public/lib/db/services.php:1982-1989)` → si lo abre un usuario privilegiado, puede forjar la edición de una cuenta. La defensa es server-side (capacidad + validación), no ocultar el token.

2.5 Moodle core: `mod_page` + filtrado global (2104c372962)

Atributo	Valor	Cita
Render	<code>format_text(..., noclean=true)</code>	<code>public/mod/page/view.php:90-93</code>
<code>trusttext</code> por defecto	0 (desactivado)	<code>locallib.php:53</code>
<code>¿trusttext activo?</code>	<code>!empty(\$CFG->enabletrusttext)</code>	<code>weblib.php:958-961</code>
<code>¿texto confiable?</code>	activo y <code>capability</code>	<code>weblib.php:949-950</code>
<code>Capability</code>	<code>moodle/site:trustcontent</code> (<code>RISK_XSS</code> , solo profesor/manager)	<code>db/access.php:452-454</code>
<code>noclean</code> en salida	<code>\$formatoptions->noclean = true</code>	<code>public/mod/page/lib.php:352</code>
<code>purify_html</code> (otros contextos)	HTMLPurifier quita <code><script></code> en texto no <code>noclean</code>	<code>weblib.php:1105-1107</code>
<code>enabletrusttext</code> por defecto	0 (desactivado)	<code>public/admin/settings/security.php:68</code>
X-Frame-Options	<i>sameorigin</i> salvo <code>\$CFG->allowframembedding</code>	<code>weblib.php:1604-1605</code>
CSP global	ninguna por defecto	<code>weblib.php</code> (NOT FOUND)

Veredicto (verificado en vivo): en `mod_page`, `<script>` y `<img onerror>` se ejecutan — `noclean=true` hace que `format_text` traduzca a `clean=false` y **no** pase por HTMLPurifier. El filtrado `purify_html` aplica a otros campos de texto no confiable (sin `noclean`), **no** a la salida de `mod_page`. La protección de `mod_page` es la **capacidad** de crear/editar la Página (`mod/page:addinstance`; HTML confiable ligado a `moodle/site:trustcontent`, `RISK_XSS`), no el saneado. `enabletrusttext=0` por defecto **no** impide la ejecución porque `mod_page` usa `noclean`.

2.6 eXeLearning core / contenido exportado (8101f54e)

Atributo	Valor	Cita
SCORM API walk	<code>window.parent (500) + win.top.opener</code> , sin validación de origen	<code>SCORM_API_wrapper.js:71-77, :136-141</code>
<code>localStorage</code>	clave <code>exeTeacherMode</code> (revela contenido de profesor)	<code>exe_export.js:100-130</code>
<code>postMessage</code> listener <code>eval()</code>	valida type, no <code>event.origin</code> sí (callbacks de carga de script, tooltips, <code>onclick</code>)	<code>asset_url_resolver.js:905-906</code> <code>common.js:805,810,757;</code> <code>common_edition.js:39</code>
MathJax	local empaquetado (no CDN)	<code>common.js:26-115</code>
iframes exportados	sin sandbox	<code>asset_url_resolver.js:933-936</code>
Validación server-side	ninguna (HTML exportado es estático/self-contained)	—

2.7 wp-exelearning (9eb07ff)

Atributo	Valor	Cita
Modo iframe	ajuste <code>exelearning_iframe_sandbox_mode: secure (def.) / legacy</code> ; helper único, <i>fail-safe</i> a <code>secure</code>	<code>includes/class-iframe-sandbox.php</code>
iframe (secure)	<code>sandbox="allow-scripts allow-popups"</code> (sin <i>same-origin</i> → opaco) + <code>referrerpolicy="no-referrer"</code>	<code>public/class-shortcodes.php</code> (<code>sandbox_tokens()</code>)
iframe (legacy)	<code>sandbox="allow-scripts allow-same-origin allow-popups"</code> (<i>same-origin</i>)	<code>class-iframe-sandbox.php</code> (<code>TOKENS_LEGACY</code>)

Atributo	Valor	Cita
Teacher mode (secure)	server-side por la <code>src</code> (<code>exe-teacher/exe-teacher-toggler</code>), aplicado por el content proxy	<code>includes/class-content-proxy.php</code>
Content proxy	<code>permission_callback => '_return_true'</code> (lectura no autenticada por hash SHA1)	<code>includes/class-exelearning-rest-api.php:44-50</code>
Nonce en guardado	usa <code>permission_callback</code> (capability), no <code>wp_verify_nonce</code>	<code>rest-api.php:223</code>
Nonce en editor	<code>wp_verify_nonce</code> al cargar página	<code>class-exelearning-editor.php:111</code>

2.8 omeka-s-exelearning (33faf89)

Atributo	Valor	Cita
Modo iframe	ajuste <code>exelearning_iframe_mode: secure</code> (def.) / <code>legacy</code> ; helper único, <i>fail-safe</i> a <code>secure</code>	<code>src/Service/IframeSandbox.php</code>
iframe (secure)	<code>sandbox="allow-scripts allow-popups allow-popups-to-escape-sandbox"</code> (sin <code>same-origin</code> → opaco); también en las dos vistas públicas (antes fijadas a <code>allow-same-origin</code>)	<code>ExeLearningRendererer.php</code> , <code>view/.../public/*-show.phtml</code>
iframe (legacy) src	añade <code>allow-same-origin</code> fijado por JS desde <code>window.location</code> (prefijo de base)	<code>IframeSandbox::tokens()</code> <code>ExeLearningRendererer.php</code>
CSRF postMessage	token obligatorio (rechaza vacío/nulo) mixto: <code>editor.js:83</code> usa <code>'*'</code> ; <code>omeka-exe-download.js:122-125</code> y <code>omeka-exe-bridge.js:46</code> usan origen específico	<code>src/Controller/CsrfValidationTrait.php:24-38</code> citas

2.9 wp-franer (7fbf694) — patrón de referencia

Atributo	Valor	Cita
iframe	<code>srcdoc + sandbox="allow-scripts allow-forms"</code> (sin <code>same-origin</code> /popups)	<code>public/partials/franer-public-render.php:141-148</code>
CSP inyectada	<code>default-src 'none'; ... connect-src 'none'; form-action 'none'; base-uri 'none'</code>	<code>includes/class-franer-sanitizer.php:48</code>
Escapado <code>srcdoc</code>	<code>_wp_specialchars(..., double_encode=true)</code>	<code>sanitizer.php:150-154</code>
Validación mensaje	<code>event.source</code> contra <code>contentWindow</code> conocido	<code>public/js/franer-shell.js:89-100, :115-117, :344-355</code>
Fetch autenticado	lo hace el padre , con <code>X-WP-Nonce</code>	<code>franer-shell.js:288-295</code>

3. Mitigaciones emparejadas (riesgo → mitigación → limitación)

Riesgo	Mitigación	Qué no resuelve
Lectura de cookies de sesión	<code>HttpOnly + SameSite=Strict</code>	No protege frente a XSS en el mismo origen ni a tokens expuestos en el DOM
Acceso al parent / mismo origen	iframe de origen opaco sin <code>allow-same-origin</code> (o <code>srcdoc</code> , o subdominio)	Rompe el bridge SCORM directo (<code>window.API</code>); exige bridge <code>postMessage</code>
Localización/envío de formularios con <code>sesskey</code> /nonce	Validación server-side del token por acción + capacidades mínimas	Si el server confía en el cliente, ocultar el token en el DOM no sirve
<code>postMessage</code> no validado	Allowlist cerrada + validación de <code>event.origin</code> y <code>event.source</code>	Una allowlist mal mantenida reabre la superficie
Ejecución de JS arbitrario	CSP restrictiva + <code>sandbox</code> sin <code>allow-same-origin</code>	El contenido legítimo que necesita JS (SCORM/H5P) exige arquitectura de bridge explícita
Navegación superior / popups	Omitir <code>allow-top-navigation</code> y <code>allow-popups-to-escape-sandbox</code>	Puede degradar UX de contenido legítimo que abre recursos externos

Principio rector: la mitigación efectiva vive en el **servidor** y en las **cabeceras**, no en confiar en que el cliente “no encuentre” el token.

4. Tabla de concienciación (perfil no técnico)

Riesgo detectado	Por qué importa	Mitigación	Limitación de la mitigación
El recurso puede leer la cookie de sesión	Permitiría suplantar al usuario autenticado	HttpOnly + SameSite=Strict	No cubre XSS en el mismo origen
El recurso accede al marco padre	Acceso al DOM autenticado del LMS	Origen opaco sin allow-same-origin	Rompe SCORM directo; exige bridge
El recurso localiza el sesskey /nonce	Primer paso para forzar acciones	Validación server-side por acción	Inútil si el server confía en el cliente
El recurso localiza formularios de edición	Permitiría crear/modificar contenido	Capacidades mínimas + validación server-side	Depende de la configuración de roles
postMessage sin validar origen/source	Canal de control no autenticado	Allowlist + validación origin/source	Allowlist mal mantenida reabre el hueco